مقيد

شركة القيروان لنظم المعلومات

ملف الشركة ونطاق البرنامج

برنامج الالتزام بالضوابط الأساسية للأمن السيبراني · الوثيقة الأولى من دراسة حالة QIS

رقم الوثيقة	**QIS-PRF-001**
الإصدار	٠٫٤ (مسودة للاعتماد)
التاريخ	١١ نوفمبر ٢٠٢٦م
التصنيف	مقيد
إشارة المشاركة	برتقالي · TLP:AMBER

إعداد نايف السالم، قائد الحوكمة والمخاطر والالتزام

دراسة حالة افتراضية. شركة القيروان لنظم المعلومات (QIS) وموظفوها وعملاؤها جهات وشخصيات افتراضية أُعدّت لملف أعمال مهني، وأي تشابه مع جهة حقيقية غير مقصود. أما الجهات التنظيمية والأطر المذكورة فهي حقيقية. لغة الوثيقة. تصدر هذه الوثيقة باللغتين العربية والإنجليزية، وفي حال وجود تعارض بين النصين يُعتمد النص العربي.

ضبط الوثيقة

الدور	الاسم	الحالة
إعداد	نايف السالم، قائد الحوكمة والمخاطر والالتزام	مكتمل
مراجعة	ريم العتيبي، الرئيس التنفيذي للتقنية	قيد الانتظار
اعتماد	فيصل الحربي، الرئيس التنفيذي	قيد الانتظار

سجل الإصدارات

الإصدار	التاريخ	المُعِدّ	التغيير
٠٫١	٢٤ أكتوبر ٢٠٢٦م	نايف السالم	المسودة الأولى للمراجعة، والنص العربي هو النص المرجعي
٠٫٢	٤ نوفمبر ٢٠٢٦م	نايف السالم	حسم البنود المفتوحة الأربعة، وإضافة المتعاقدين ومكونات مكتب جدة، وتجهيز الوثيقة للاعتماد
٠٫٣	١٠ نوفمبر ٢٠٢٦م	نايف السالم	اعتماد الهوية البصرية الجديدة وصفحة الغلاف، وتحسين قابلية القراءة، وإضافة وسوم أمن المعلومات (التصنيف، والعلامة المائية، وإشارة المشاركة وفق مستويات الهيئة الوطنية للأمن السيبراني)، واعتماد اسم الشركة «شركة القيروان لنظم المعلومات».
٠٫٤	١١ نوفمبر ٢٠٢٦م	نايف السالم	اعتماد الأرقام الهندية في جميع أرقام الوثيقة، وكتابة أرقام الضوابط بالترتيب المتبع في وثائق الهيئة الوطنية للأمن السيبراني، تيسيراً للبحث عنها في نصوص الهيئة.

التصنيف وإشارة المشاركة

الوسم	المستوى	ما يعنيه
التصنيف	مقيد	يؤدي الإفصاح غير المصرح به إلى ضرر محدود، ويقتصر الاطلاع على من تحددهم الشركة.
إشارة المشاركة (TLP)	برتقالي	مشاركة محدودة داخل جهة المستلم مع المعنيين فقط.

دورة المراجعة: سنوياً، أو قبل ذلك عند تغيّر خدمات الشركة أو عملائها أو الأنظمة واللوائح المنطبقة عليها.

١. الغرض

تحدد هذه الوثيقة هوية شركة القيروان لنظم المعلومات، وما تقدمه من خدمات، ونطاق برنامج الالتزام بالضوابط الأساسية للأمن السيبراني. وهي المرجع لكل الوثائق اللاحقة في البرنامج.

- يستمد سجل الأصول وتصنيف البيانات أصولهما من الأقسام ٣ و٤ و٦.
- يعمل سجل المخاطر وتقييم الفجوات ضمن النطاق المحدد في القسم ٩.
- تستجيب خطة معالجة المخاطر والسياسات للأهداف الواردة في القسم ٨.

تصف هذه الوثيقة الشركة كما هي عند بدء البرنامج، وتسجّل الوقائع لا الملاحظات. أما مواطن الضعف فتُحدَّد وتُقيَّم في الوثائق التالية.

٢. نبذة عن الشركة وتاريخها

شركة القيروان لنظم المعلومات شركة سعودية خاصة لخدمات تقنية المعلومات، يعمل بها نحو ٢٥٠ موظفاً. يقع مقرها الرئيس في الرياض، ولها مكتب في جدة، وتخدم ست جهات حكومية.

كلمة «قيروان» عربية فصيحة تعني القافلة أو موضع نزولها، وربط الناس والأنظمة هو جوهر عمل الشركة.

نمت الشركة ببطء بين عامي ٢٠١١ و٢٠١٦، ثم تسارع نموها مع تسارع التحول الرقمي الحكومي، دون أن تواكب ممارساتها الأمنية هذا النمو. وقد شكّلت الأحداث التالية القواعد التي يتعيّن على الشركة الالتزام بها اليوم.

السنة	الحدث
٢٠١١	أسّس فيصل الحربي الشركة في الرياض لتقديم خدمات تمديد الشبكات والدعم الفني للشركات الخاصة.
٢٠١٢	هجوم برمجية «شمعون» الخبيثة على أرامكو السعودية يمحو بيانات نحو ٣٠٬٠٠٠ جهاز، فيصبح الأمن السيبراني أولوية وطنية. ولم تُجرِ الشركة، وكانت صغيرة آنذاك، أي تغيير.
٢٠١٤	فوز الشركة بأول عقد حكومي لصيانة تطبيق قديم لدى العميل (و).
٢٠١٦	إطلاق رؤية السعودية ٢٠٣٠، ويقود التحول الرقمي الحكومي نمواً سريعاً في أعمال الشركة الحكومية.
٢٠١٧	إنشاء الهيئة الوطنية للأمن السيبراني.

السنة	الحدث
٢٠١٨	إصدار الهيئة الضوابط الأساسية للأمن السيبراني (ECC-1:2018)، وبدء الشركة تقديم الخدمات المُدارة للعميل (ب).
٢٠١٩	افتتاح مكتب الشركة في جدة.
٢٠٢١	إطلاق بوابة المواطنين لدى العميل (أ)، وبدء استضافة أنظمة العملاء لدى مزوّد خدمات سحابية سعودي.
٢٠٢٣	دخول نظام حماية البيانات الشخصية حيّز التنفيذ.
٢٠٢٤	إصدار الهيئة النسخة المحدّثة من الضوابط (ECC-2:2024).
٢٠٢٦	اشتراط تجديد عقد العميل (أ) أن تُثبت الشركة التزامها بالضوابط، وتعيين أول قائد للحوكمة والمخاطر والالتزام.

٣. الخدمات

تقدّم الشركة ثلاثة خطوط خدمة، يربط كلٌّ منها الشركة بأنظمة العملاء أو بياناتهم بطريقة مختلفة.

خط الخدمة	ما تقدمه الشركة	العملاء
الخدمات المُدارة لتقنية المعلومات	الدعم الفني وإدارة الأجهزة الطرفية ومراقبة الشبكات لموظفي العملاء، ويتصل الفنيون بشبكات العملاء عن بُعد.	أ، ب، ج، هـ
استضافة التطبيقات	استضافة أنظمة العملاء وتشغيلها على منصة سحابية لدى مزوّد مرخّص من هيئة الاتصالات والفضاء والتقنية داخل المملكة.	أ، ج، د
تطوير البرمجيات وصيانتها	بناء تطبيقات العملاء وصيانتها وتحديثها، ومنها بوابة المواطنين لدى العميل (أ) والتطبيق القديم لدى العميل (و).	أ، و

٤. العملاء

تخدم الشركة ست جهات حكومية يُشار إليها برموز فقط، اتباعاً للممارسة المعتادة في حماية هوية العملاء.

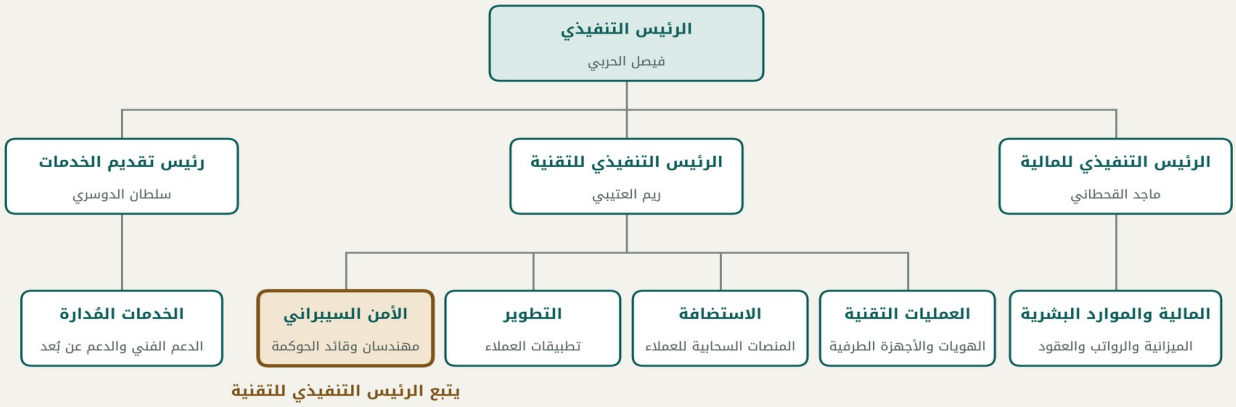
العميل	النوع	ما تقدمه الشركة	البيانات المتعامل معها	المستوى
العميل (أ)	وزارة	بنت بوابة المواطنين وتستضيفها، وتقدّم الدعم الفني. العقد قيد التجديد.	بيانات شخصية للمواطنين	حرج

العميل	النوع	ما تقدمه الشركة	البيانات المتعامل معها	المستوى
العميل (ب)	هيئة تنظيمية	خدمات مُدارة كاملة: إدارة نحو ٤٠٠ جهاز للموظفين، والدعم عن بُعد.	سجلات داخلية بعضها سري	مرتفع
العميل (ج)	جامعة حكومية	الدعم الفني، واستضافة نظام الخدمات الطلابية.	سجلات الطلاب	مرتفع
العميل (د)	بلدية	استضافة نظام إصدار التراخيص وصيانته.	بيانات المتقدمين والعقارات	متوسط
العميل (هـ)	جهة حكومية	مراقبة الشبكات والدعم عن بُعد.	إعدادات الشبكات	متوسط
العميل (و)	هيئة صغيرة	صيانة تطبيق قديم، وينتهي العقد في ٢٠٢٧م.	بيانات داخلية محدودة	منخفض

يعكس المستوى حساسية البيانات التي تتعامل معها الشركة، ثم عمق صلاحيات وصولها، بهذا الترتيب.

٥. الهيكل التنظيمي والحوكمة

يقود الشركة مؤسسها ورئيسها التنفيذي، ويتبعه ثلاثة تنفيذيين. ويقع الأمن السيبراني ضمن إدارة التقنية ويتبع الرئيس التنفيذي للتقنية، وينضم قائد الحوكمة والمخاطر والالتزام الجديد إلى خط التبعية نفسه.



الشكل ١. الهيكل التنظيمي للشركة، أكتوبر ٢٠٢٦م

القيادة وأدوار البرنامج

الاسم	المنصب	المسؤوليات	الدور في البرنامج
فيصل الحربي	الرئيس التنفيذي	المؤسس، والمسؤول الأول عن الشركة.	راعي البرنامج، ويعتمد السياسات وقبول المخاطر.
ريم العتيبي	الرئيس التنفيذي للتقنية	العمليات التقنية والاستضافة والتطوير والأمن.	تملك معظم المخاطر والضوابط التقنية.
ماجد القحطاني	الرئيس التنفيذي للمالية	المالية والموارد البشرية والعقود.	يعتمد ميزانية البرنامج، ويملك ضوابط الموارد البشرية كالتحقق قبل التوظيف وإنهاء الخدمة.
سلطان الدوسري	رئيس تقديم الخدمات	الخدمات المُدارة وفنيو العملاء والعلاقة مع العملاء.	يملك صلاحيات الوصول إلى أنظمة العملاء والالتزامات تجاههم.
نايف السالم	قائد الحوكمة والمخاطر والالتزام (انضم في أكتوبر ٢٠٢٦م)	الحوكمة وإدارة المخاطر والالتزام.	مالك البرنامج ومُعِدّ وثائقه.

عدد الموظفين حسب الوظيفة

الوظيفة	العدد
الخدمات المُدارة (الدعم الفني والدعم عن بُعد)	١٢٠
التطوير	٤٥
العمليات التقنية والاستضافة	٤٠
المالية والموارد البشرية والإدارة	٣٠
القيادة وتطوير الأعمال	١٢
الأمن السيبراني (مهندسان وقائد الحوكمة)	٣
إجمالي الموظفين	**٢٥٠**
المتعاقدون (معظمهم مطورون)	٢٠

٦. البيئة التقنية

تُعرض البيئة أدناه كما يصفها فريق تقنية المعلومات في الشركة، وهي نقطة الانطلاق لسجل الأصول.

المجال	ما تشغّله الشركة
الهويات	خدمة Active Directory داخلية أُنشئت عام ٢٠١١، ومتزامنة مع Microsoft Entra ID لخدمات البريد والملفات في Microsoft 365.
الأجهزة الطرفية	نحو ٣٠٠ حاسب محمول بنظام Windows، ويطّلع بعض الموظفين على بريد العمل من هواتفهم الشخصية.
غرفة الخوادم في المقر الرئيس	خادم ملفات قديم، ونظام قديم للمالية والموارد البشرية، وجهاز تخزين للنسخ الاحتياطية.
استضافة أنظمة العملاء	تُستضاف أنظمة العملاء لدى مزوّد خدمات سحابية سعودي مرخّص من هيئة الاتصالات والفضاء والتقنية.
الوصول إلى أنظمة العملاء	أداة للإدارة عن بُعد، وحسابات VPN لكل شبكة عميل، ويتشارك بعض الفنيين الحسابات.
التطوير	مستودعات الشيفرة المصدرية ومسار البناء الخاص ببوابة المواطنين لدى العميل (أ).
مكتب جدة	حواسب محمولة وجدار حماية وطابعة، ومتصل بالمقر الرئيس عبر شبكة افتراضية خاصة (VPN) بين الموقعين، ولا توجد فيه خوادم.
الأدوات الأمنية	جدران حماية وبرامج مكافحة فيروسات، ولا يوجد تسجيل أو مراقبة مركزية، ولا يُطبَّق التحقق متعدد العوامل على جميع الأنظمة.

٧. السياق التنظيمي

لا تُعد الشركة جهة حكومية، لكنها ملزمة بالضوابط الأساسية للأمن السيبراني عبر عملائها الحكوميين؛ إذ يجب على كل عميل تطبيق متطلبات الأمن السيبراني المتعلقة بالأطراف الخارجية على مزوّدي خدماته. وتنطبق أنظمة أخرى بسبب طبيعة البيانات التي تتعامل معها الشركة ومكان استضافتها.

الجهة	الإطار أو النظام	سبب انطباقه على الشركة
الهيئة الوطنية للأمن السيبراني	الضوابط الأساسية للأمن السيبراني (ECC-2:2024)	يجب على العملاء الحكوميين تطبيق الضوابط على مزوّدي الخدمات، ويشترط تجديد عقد العميل (أ) أن تُثبت الشركة التزامها.

الجهة	الإطار أو النظام	سبب انطباقه على الشركة
الهيئة الوطنية للأمن السيبراني	ضوابط الأمن السيبراني للحوسبة السحابية (CCC)	تستضيف الشركة أنظمة حكومية على السحابة.
هيئة الاتصالات والفضاء والتقنية	الإطار التنظيمي للحوسبة السحابية	تستضيف الشركة أنظمة العملاء لدى مزوّد سحابي مرخّص داخل المملكة.
الهيئة السعودية للبيانات والذكاء الاصطناعي (سدايا)	نظام حماية البيانات الشخصية	تعالج بوابة المواطنين لدى العميل (أ) ونظام الطلاب لدى العميل (ج) بيانات شخصية.
مكتب إدارة البيانات الوطنية (التابع لسدايا)	المعايير الوطنية لإدارة البيانات وتصنيفها وحماية البيانات الشخصية	تتعامل الشركة مع بيانات حكومية يصنّفها العملاء وفق هذه المعايير.

ملاحظة التحقق. تعكس هذه المراجع المعرفة العملية للمُعِدّ حتى أكتوبر ٢٠٢٦م، ويجب التحقق من الإصدار الحالي لكل منها عبر المواقع الرسمية للهيئة الوطنية للأمن السيبراني وهيئة الاتصالات والفضاء والتقنية وسدايا قبل اعتماد هذه الوثيقة.

٨. محفّز البرنامج وأهدافه

ينتهي عقد العميل (أ) في ٣٠ أبريل ٢٠٢٧م، ويشترط تجديده أن تُثبت الشركة التزامها بالضوابط الأساسية للأمن السيبراني (ECC-2:2024) بصفتها مزوّد خدمة للعميل. وبذلك تتاح للبرنامج ستة أشهر.

#	الهدف	دليل التحقق	الموعد
١	إنشاء إدارة مستقلة للأمن السيبراني	تتبع الإدارة الرئيس التنفيذي، واعتماد ميثاق الأمن السيبراني.	ديسمبر ٢٠٢٦م
٢	حصر الأصول وتصنيفها	اعتماد سجل الأصول وتصنيف البيانات.	نوفمبر ٢٠٢٦م
٣	تقييم مخاطر الأمن السيبراني	اعتماد منهجية إدارة المخاطر وسجل المخاطر من الرئيس التنفيذي.	ديسمبر ٢٠٢٦م
٤	قياس مستوى الالتزام بالضوابط	إكمال تقييم الفجوات لكل ضابط منطبق.	ديسمبر ٢٠٢٦م
٥	معالجة المخاطر ذات الأولوية	تمويل خطة المعالجة، وسير الإجراءات الحرجة والمرتفعة وفق الجدول.	مارس ٢٠٢٧م
٦	وضع إطار الحوكمة	اعتماد سياسات الأمن السيبراني الأساسية وتعميمها على الموظفين.	فبراير ٢٠٢٧م

#	الهدف	دليل التحقق	الموعد
٧	إثبات الالتزام	قبول العميل (أ) لحزمة الأدلة.	أبريل ٢٠٢٧م

حوكمة البرنامج

- **الراعي:** فيصل الحربي، الرئيس التنفيذي
- **المالك:** نايف السالم، قائد الحوكمة والمخاطر والالتزام
- **اللجنة الإشرافية:** الرئيس التنفيذي، والرئيس التنفيذي للتقنية، والرئيس التنفيذي للمالية، ورئيس تقديم الخدمات، وقائد الحوكمة والمخاطر والالتزام. تجتمع شهرياً لمتابعة التقدم واعتماد القرارات وقبول المخاطر.

٩. النطاق

داخل النطاق

- خطوط الخدمة الثلاثة: الخدمات المُدارة لتقنية المعلومات، واستضافة التطبيقات، وتطوير البرمجيات وصيانتها.
- المقر الرئيس في الرياض ومكتب جدة.
- تقنية المعلومات المؤسسية: الهويات، والبريد والملفات، والأجهزة الطرفية، وغرفة الخوادم في المقر الرئيس، ونظام المالية والموارد البشرية.
- الأنظمة التي تستضيفها الشركة أو تبنيها أو تديرها للعملاء من (أ) إلى (و).
- جميع موظفي الشركة (٢٥٠ موظفاً) والمتعاقدين معها (نحو ٢٠ متعاقداً).
- الأطراف الخارجية التي تعتمد عليها الشركة، ومنها مزوّد الخدمات السحابية وموزّدو البرمجيات.

خارج النطاق

المجال	السبب
أنظمة العملاء وشبكاتهم الخاصة خارج نطاق الخدمات المُدارة	كل عميل مسؤول عن بيئته.
البنية التحتية الداخلية لمزوّد الخدمات السحابية	تغطيها التزامات المزوّد وشهاداته وفق نموذج المسؤولية المشتركة.
الأمن المادي لمقار العملاء	يخضع لسيطرة كل عميل.

الافتراضات والقيود

- **الموعد النهائي:** ستة أشهر حتى تجديد عقد العميل (أ) في ٣٠ أبريل ٢٠٢٧م.
- **الطاقة الاستيعابية:** يتكون فريق الأمن من مهندسَين، وقائد الحوكمة هو المورد الوحيد للحوكمة.
- **الميزانية:** لم تُحدَّد بعد، وسيعتمد الرئيس التنفيذي للمالية التمويل بعد تقييم المخاطر.
- **الأدلة:** لغياب التسجيل المركزي، سيُجمع بعض أدلة الالتزام يدوياً.
- **الرعاية:** تستمر رعاية الرئيس التنفيذي طوال مدة البرنامج.

١٠. الوثائق ذات العلاقة

ينتج البرنامج الوثائق التالية بهذا الترتيب، وتستند كل وثيقة إلى ما قبلها.

رقم الوثيقة	الوثيقة	مرحلة البرنامج
QIS-PRF-001	ملف الشركة ونطاق البرنامج (هذه الوثيقة)	١. السياق
QIS-AST-001	سجل الأصول	٢. التحديد
QIS-DCL-001	تصنيف البيانات	٢. التحديد
QIS-RMM-001	منهجية إدارة المخاطر	٣. التقييم
QIS-RR-001	سجل المخاطر	٣. التقييم
QIS-GAP-001	تقييم الفجوات في الضوابط الأساسية	٣. التقييم
QIS-RTP-001	خطة معالجة المخاطر	٤. المعالجة
QIS-POL-001 وما بعدها	سياسات الأمن السيبراني	٥. الحوكمة
QIS-IRP-001	خطة الاستجابة للحوادث	٦. التشغيل
QIS-IAR-001	تقرير المراجعة الداخلية	٦. التشغيل

الملحق (أ). القرارات المتخذة في الإصدار ٠٫٢

حُسمت البنود المفتوحة في الإصدار ٠٫١ على النحو التالي.

#	البند	القرار
١	توقيت تحديد ميزانية البرنامج	تُحدَّد بعد تقييم المخاطر، لتُوجَّه الموارد إلى أعلى المخاطر.

#	البند	القرار
٢	عدد المتعاقدين ووظائفهم	نحو ٢٠ متعاقداً، معظمهم مطورون.
٣	مكونات مكتب جدة	حواسب محمولة وجدار حماية وطابعة فقط، دون خوادم.
٤	موعد تجديد عقد العميل (أ)	٣٠ أبريل ٢٠٢٧م.

مقيد